

SOC L1 UYARI ÖN DEĞERLENDİRMESİ

[Kaynak](#)

İÇERİK

1. Olaylar ve Alarmlar (Events and Alerts)
2. Alarm Özellikleri (Alert Properties)
3. Alarm Önceliklendirme (Alert Prioritisation)
4. Alarm Triyajı (Alert Triage) Süreci ve Operasyonel Metodoloji

Olaylar ve Alarmlar (Events and Alerts)

Olaydan Alarma Geçişin Anatomisi (From Events to Alerts)

Siber güvenlik operasyonlarının temelinde, devasa bir veri yığınının içinden gerçekten kritik olan tehditleri ayıklamak yatar. Bu sürecin en alt katmanında **Event** (Olay - sistem üzerinde gerçekleşen herhangi bir durum veya aktivite) bulunur. Bir kullanıcının sisteme giriş yapması, bir sürecin (process) başlatılması, ağ üzerinden bir dosyanın indirilmesi veya bir servisin çökmesi tamamen birer olaydır.

Ancak bir olayın tek başına hiçbir analitik değeri yoktur; bu olayın işletim sistemi, **Firewall** (Güvenlik Duvarı) veya bulut altyapısı tarafından kayıt altına alınması, yani bir **Log** (Günlük) haline getirilmesi gerekir.

ÖNEMLİ: Gerçek dünya senaryolarında, bir **SOC** (Security Operations Center - Siber Güvenlik Operasyon Merkezi) ekibi binlerce farklı uç noktadan ve ağ cihazından günde milyonlarca, bazen milyarlarca ham log alır. İnsan kapasitesiyle bu logların tek tek incelenmesi (manual log review) imkansızdır.

İşte bu noktada **Alert** (Alarm - belirli bir olay veya olaylar dizisi gerçekleştiğinde güvenlik çözümleri tarafından üretilen bildirim) devreye girer. Alarmlar, arka planda çalışan korelasyon kuralları (correlation rules) sayesinde, beklenen ve normal olan olayları filtreleyerek sadece şüpheli ve anomalik durumları analistin önüne getirir. Böylece analist, milyonlarca satır log yerine günde yalnızca yüksek öncelikli ve incelenmesi gereken birkaç düzine alarmı **Triage** (Trijaj - gelen bildirimlerin tehlike seviyesine göre önceliklendirilmesi ve ilk analizi) işlemine tabi tutar.

Arka planda bir alarmın nasıl oluştuğunu ve karşımıza nasıl çıktığını daha iyi kavramak için tipik bir **SIEM** (Security Information and Event Management) alarm çıktısını inceleyelim:

```
{  
  "alert_id": "ALR-9982",  
  "rule_name": "Unapproved Mimikatz Usage",
```

```
"severity": "Critical",
"timestamp": "2026-05-07T10:15:30Z",
"host": "WKSTN-FINANCE-04",
"user": "corp\\jdoe",
"process_command_line": "mimikatz.exe privilege::debug
sekurlsa::logonpasswords exit",
"mitre_tactic": "Credential Access"
}
```

Yukarıdaki JSON çıktısı, basit bir olayın nasıl yapılandırılmış bir alarmla dönüştüğünü gösterir. Eğer bu süreç başarısız olsaydı veya sistemde düzgün bir loglama/korelasyon mimarisi kurulmamış olsaydı, "jdoe" kullanıcısının bilgisayarında bellekten parola çıkaran (dumping) bu **Mimikatz** aktivitesi milyonlarca Windows Event ID (özellikle Event ID 4688 - Process Creation) arasında kaybolup gidecekti. Bu alarm sayesinde doğrudan **WKSTN-FINANCE-04** makinesine odaklanmamız ve "Credential Access" (Kimlik Bilgisi Erişimi) taktığının uygulandığını anlamamız sağlanır.

Alarm Yönetim Platformları ve Mimarisi

SOC ortamlarında alarmların merkezi olarak yönetilmesi ve zenginleştirilmesi için farklı mimari çözümler kullanılır. Birbirinden farklı sistemlerin nasıl entegre çalıştığını anlamak, operasyonel hız (MTTR - Mean Time to Respond) açısından kritik öneme sahiptir.

- **SIEM (Security Information and Event Management):** **Splunk ES** veya **Elastic** gibi platformlar. Çoğu SOC ekibinin kalbini oluşturur. Ağdaki tüm logların toplandığı, normalize edildiği ve yukarıda bahsettiğimiz kuralların çalıştırılarak alarmların üretildiği ana merkezdir. Mükemmel bir alarm yönetim kapasitesine sahiptir.
- **EDR / NDR (Endpoint/Network Detection and Response):** **MS Defender** veya **CrowdStrike** gibi uç nokta ve ağ tabanlı tehdit algılama çözümleri. Kendi içlerinde son derece yetenekli alarm dashboard'larına (panellerine) sahip olmalarına rağmen, sektör standardı ve best-practice (en iyi uygulama) olarak bu platformların ürettiği alarmlar doğrudan SIEM veya SOAR platformlarına iletilir (forwarding). Bu sayede analist, birden fazla ekrana bakmak (swivel-chair analysis) zorunda kalmaz.
- **SOAR (Security Orchestration, Automation, and Response):** **Splunk SOAR** veya **Cortex XSOAR** gibi sistemler. Özellikle büyük ve olgun SOC ekiplerinde kullanılır. Birden fazla güvenlik çözümünden gelen alarmları tek bir noktada toplar (aggregation) ve en önemlisi **Playbook**'lar (otomatize edilmiş müdahale senaryoları) aracılığıyla analiz ve engelleme süreçlerinin büyük bir kısmını makine hızında otomatikleştirir.
- **ITSM (IT Service Management):** **Jira** veya **TheHive** (özellikle SOC için özelleştirilmiş bir vaka yönetim aracı). Alarmların birer "Vaka" (Case/Ticket) haline getirilip, ekipler arası görev atamalarının, analiz notlarının ve bulguların (IoC - Indicators of Compromise) kaydedildiği platformlardır.

Alarm Triyaj (Triage) Sürecinde SOC Katmanları ve Roller

Bir alarm düştüğünde, SOC ekibindeki her bir üyenin sürecin kusursuz işlemesi için spesifik bir sorumluluğu vardır.

SOC L1 Analyst (1. Seviye Analist): Savunmanın en ön hattıdır. Alarm yönetim sistemleriyle en çok vakit geçiren ekiptir. Gelen alarmların **False Positive** (Yanlış Pozitif - zararlı gibi görünen ama aslında zararsız olan veya beklenen aktivite) mi yoksa **True Positive** (Gerçek Pozitif - gerçek bir saldırı veya politika ihlali) mi olduğunu ayırt etmekle yükümlüdürler. Eğer ortada gerçek bir tehdit tespit edilirse, gerekli ilk kanıtları (IP adresleri, dosya hashleri vb.) toplayıp vakayı L2 analistlere tırmandırırlar (Escalation).

SOC L2 Analyst (2. Seviye Analist / Incident Responder): L1 tarafından tırmandırılan (escalate edilen) vakaları devralırlar. Yüzeysel triyajın ötesine geçerek derinlemesine adli bilişim (Deep Forensics) analizi yaparlar. "Saldırgan sisteme nasıl girdi?", "Hangi dosyaları değiştirdi?", "Ağda yanal hareket (Lateral Movement) yaptı mı?" gibi soruların cevaplarını bulur ve tehdidi sistemden tamamen kazımak için Remediation (İyileştirme/Müdahale) adımlarını yönetirler.

SOC Engineers (SOC Mühendisleri / SIEM Mühendisleri): Analistlerin operasyonel olarak kör kalmaması için arka planı inşa eden ekiptir. Sistemlerden gelen logların düzgün bir şekilde parse (ayrıştırılma) edildiğinden emin olurlar. Loglarda eksik bilgi varsa (örneğin kayıtlarda kaynak IP adresi görünmüyorsa), analistlerin triyaj sürecini verimli yapabilmesi için gerekli teknik altyapıyı onarırlar ve korelasyon kurallarını yazarlar.

SOC Manager (SOC Yöneticisi): Analiz süreçlerinin teknik detayından ziyade, operasyonun hızı ve kalitesiyle ilgilenir. Gerçek bir saldırının gözden kaçmaması ve SLA (Service Level Agreement - Servis Seviyesi Anlaşması) sürelerine uyulması için alarm triyaj hızını (örneğin bir alarmın L1 tarafından kaç dakikada kapatıldığı) takip eder ve ekibin performansını metriklerle ölçer.

DİKKAT: Bir SOC ortamında başarılı bir operasyon; iyi parse edilmiş logların mühendisler tarafından doğru kurallarla alarmlara dönüştürülmesine, bu alarmların SIEM/SOAR üzerinde L1 tarafından hızlıca triyajlanıp gürültünün (noise) filtrelenmesine ve gerçek tehditlerin L2 tarafından kök neden analiziyle (Root Cause Analysis) yok edilmesine bağlıdır. Her bir adım, bir zincirin halkasıdır.

Alarm Özellikleri (Alert Properties)

Bir **SOC** (Security Operations Center - Siber Güvenlik Operasyon Merkezi) ortamında alarmların nasıl üretildiğini anladıktan sonraki en kritik adım, bu alarmların anatomisini yapısal olarak parçalarına ayırmaktır. Herhangi bir **SIEM** (Security Information and Event Management) veya güvenlik çözümü (EDR, NDR vb.) farklı arayüzlere sahip olsa da, üretilen bir alarmın çekirdek veri yapısı evrenseldir.

Bu özellikler, bir alarmın sadece ne olduğunu değil, analistin **Triage** (Trijaj - gelen alarmların analiz edilip önceliklendirilmesi süreci) aşamasında nasıl bir aksiyon alması gerektiğini belirleyen temel yapı taşlarıdır.

Zaman ve Kimlik Metrikleri

İlk inceleme aşamasında bir olayın ne zaman gerçekleştiği ve sistemin buna ne zaman tepki verdiği hayati bir ayrımı ortaya koyar.

- **Alert Time (Alarm Zamanı) ve Event Time (Olay Zamanı):** **Event Time**, saldırının veya şüpheli aktivitenin uç noktada (endpoint) veya ağ cihazında fiziksel olarak gerçekleştiği tam andır. **Alert Time** ise bu olaya ait logların ağ üzerinden SIEM'e iletilmesi (log shipping), ayrıştırılması (parsing) ve bir korelasyon kuralıyla eşleşerek alarmin analistin ekranına düştüğü andır. **ÖNEMLİ:** Bu iki zaman dilimi arasında genellikle birkaç dakikalık bir gecikme (latency) olur. Eğer Event Time ile Alert Time arasındaki fark dakikalardan saatlere çıkıyorsa, sistemin log toplama mimarisinde (örneğin log ileticilerin çökmesi veya ağ darboğazları) kritik bir arıza var demektir. Olay müdahalesi (Incident Response) sırasında her zaman **Event Time** baz alınarak zaman çizelgesi (timeline) oluşturulur.
- **Alert Name (Alarm Adı):** Tetiklenen tespit kuralının (detection rule) adıdır. Analiste olayın bağlamını ilk saniyede verir (Örn: **Windows RDP Bruteforce, Potential Data Exfiltration**). İyi yazılmış bir alarm adı, olayın hangi **MITRE ATT&CK** taktiğine veya tekniğine denk düştüğünü dolaylı olarak belirtmelidir.

Time	Name	Severity	Status	Verdict	Assignee	Actions
1 Mar 21st 2025 at 11:53	2 Bruteforce Attack from External	3 Medium	4 Closed	5 ✓ True Positive	6 J.Adams (L2)	
Mar 21st 2025 at 13:58	Double-Extension File Creation	High	Awaiting action	None	None	
Description: This rule detects a creation of a double-extension file like '*.pdf.exe' or '*.gif.lnk', often used by hackers in phishing attacks to trick users into opening the malicious executable.						
Host: LPT-HR-009						
Process Name: chrome.exe						
Process User: S.Conway						
Target File: C:\Users\S.Conway\Downloads\cats2025.mp4.exe						
File MotW: https://freecatvideoshd.monster/cats2025.mp4.exe						
File MD5: 14d8486f3f63875ef93cfd240c5dc10b						

Önceliklendirme, Yaşam Döngüsü ve Sınıflandırma

Bir analistin ekranına aynı anda düşen yüzlerce alarm arasından hangisine ilk olarak müdahale edeceğini belirleyen metriklerdir.

- **Alert Severity (Önem/Kritiklik Derecesi):** Alarmin aciliyetini tanımlar. Algılama mühendisleri (Detection Engineers) tarafından potansiyel etkiye (impact) göre önceden ayarlanır. Genellikle (●) **Low / Informational** (Düşük/Bilgi), (●) **Medium / Moderate** (Orta), (●) **High / Severe** (Yüksek) ve (●) **Critical / Urgent** (Kritik) şeklinde sınıflandırılır. **DİKKAT:** Severity sadece bir tavsiyedir. Zeki bir analist, **Low** seviyeli bir "Yeni Kullanıcı Oluşturuldu" alarminın, kritik bir Domain Controller sunucusunda gerçekleştiğini fark ettiğinde, bu alarmin seviyesini manuel olarak **Critical**'a çekip acil müdahale sürecini (SLA - Service Level Agreement sınırları içinde) başlatmalıdır.
- **Alert Status (Alarm Durumu):** Alarmin operasyonel yaşam döngüsündeki (lifecycle) yerini belirtir.
 - (NEW) **New / Unassigned:** Henüz kimse tarafından incelenmemiş.

- (🔄) **In Progress / Pending**: Bir analist üzerinde çalışıyor.
- (✅) **Closed / Resolved**: Triyaj ve gerekli aksiyonlar tamamlanmış, alarm kapatılmış.
- **Alert Verdict (Alarm Kararı / Sınıflandırma)**: İnceleme sonucunda analistin verdiği nihai teknik karardır. Olayın gerçek bir tehdit olup olmadığını ayırır.
 - (🔴) **True Positive (Gerçek Pozitif)**: Alarmin tespit ettiği olay gerçekten bir saldırı veya politika ihlalidir.
 - (🟢) **False Positive (Yanlış Pozitif)**: Sistem meşru ve zararsız bir aktiviteyi yanlışlıkla tehdit olarak algılamıştır. Bir SOC'un olgunluğu, **False Positive** oranını düşürmek için SIEM kurallarının sürekli olarak optimize edilmesiyle (Rule Tuning) ölçülür.

Bağlam, Mantık ve Adli Bilişim Verileri

Bir alarmin arka planındaki mantığı ve olayı doğrulamak için gereken somut kanıtları içeren bölümdür.

- **Alert Assignee (Atanan Kişi / Alarm Sahibi)**: Alarmı inceleme sorumluluğunu alan analisti gösterir (Chain of Custody). Aynı alarm üzerinde birden fazla analistin efor israfı yapmasını engeller. "Owner" (Sahip) kavramı, o alarm kapatılana kadar tüm sorumluluğun o analiste ait olduğunu belirtir.
- **Alert Description (Alarm Açıklaması)**: Kuralın neden tetiklendiğini anlatan "Rehber" niteliğindeki metindir. Genellikle üç temel mantık içerir:
 1. Kuralın çalışma mantığı (Hangi olaylar bir araya gelince bu alarm oluşur?).
 2. Bu aktivitenin neden bir saldırı göstergesi (IoA - Indicator of Attack) olabileceği.
 3. Analistin bu alarmı nasıl incelemesi gerektiğine dair adımlar (Runbook/Playbook yönergeleri). *B Planı*: Eğer alarm açıklaması boş bırakılmışsa veya yetersizse, analist doğrudan SIEM kuralının kaynak koduna/sorgusuna (SPL, KQL vb.) inip kuralı kendi başına tersine mühendislikle çözmek (reverse-engineer) zorundadır.
- **Alert Fields (Alarm Alanları / Metadatalar)**: Alarmı tetikleyen somut teknik verilerdir. Siber istihbarat ve adli bilişim incelemesi tamamen bu alanlar üzerinden yürütülür. **Affected Hostname** (Etkilenen Makine Adı), **Source IP** (Kaynak IP), **Target User** (Hedef Kullanıcı), **Entered Commandline** (Çalıştırılan Komut Satırı) veya **File Hash** (Dosya Özeti) gibi verileri içerir.

Gerçek Dünya Senaryosu: Bir Alarmin Anatomisi

Yukarıdaki teorik özelliklerin bir SIEM platformunda (Örn: Splunk veya Elastic) JSON formatında nasıl görüntülendiğini ve arka planda ne anlama geldiğini satır satır inceleyelim:

```
{
  "alert_id": "ALR-20260507-001",
  "rule_name": "Unusual Commandline - Potential Base64 Encoded Payload",
  "times": {
```

```
"event_time": "2026-05-07T14:30:12Z",
"alert_time": "2026-05-07T14:32:05Z"
},
"triage": {
  "severity": "High",
  "status": "In Progress",
  "assignee": "analyst.gokhan",
  "verdict": "Unassigned"
},
"description": "Rule detects overly long command line executions
containing 'powershell' and '-enc' flags.",
"fields": {
  "hostname": "FINANCE-WKS-04",
  "username": "corp\\jdoe",
  "parent_process": "winword.exe",
  "command_line": "powershell.exe -nop -w hidden -enc
JABzAD0ATgBLAHcALQBPAgIAagBLAGMAAdAAgAEkATwAuAE0AZQBtAG8AcgB5AFMAAdABYAGUAYQBt
ACgAWwBDAG8AbgB2AGUAcgB0AF0A0gA6AEYAcgBvAG0AQgBhAHMAZQA2ADQAUwB0AHIAaQBuAGcA
KAAiAEgA..."
}
}
```

Satır Satır Analitik Yorumlama:

- Zaman Analizi (times bloğu):** Event Time ile Alert Time arasında yaklaşık 2 dakikalık bir gecikme var. Bu, makul ve sağlıklı bir log iletim (ingestion) süresidir. Müdahale zaman çizelgesini 14:30:12Z üzerinden kurmamız gerekir.
- Öncelik ve Durum (triage bloğu):** Alarmin kritikliği **High**. Şu an **analyst.gokhan** tarafından inceleniyor (In Progress). Henüz bir karar verilmediği için verdict alanı boş (Unassigned).
- Açıklama (description bloğu):** Alarmin mantığını açıkça görüyoruz; PowerShell üzerinden Base64 ile encode (şifrelenmiş/kodlanmış) edilmiş uzun komut satırlarını yakalamak için yazılmış.
- Adli Bilişim Alanları (fields bloğu - En Kritik Aşama):**
 - Hostname ve Username:** Zafiyetin **FINANCE-WKS-04** makinesinde ve **jdoe** kullanıcısının oturumunda gerçekleştiğini görüyoruz. (Finans departmanı makineleri genellikle en kritik hedeflerdir).
 - Parent Process (Üst Süreç):** Komutu başlatan uygulamanın **winword.exe** (Microsoft Word) olduğu görülüyor. **MANTIK ZİNCİRİ:** Neden bir Word belgesi arka planda gizli (-w hidden) ve profilsiz (-nop) bir PowerShell başlatır? Bu durum, yüksek ihtimalle kullanıcının oltalama (Phishing) maili ile gelen makro (Macro) destekli bir Word dökümanını açtığını ve zararlı yazılımın (Payload) sisteme inmeye başladığını gösterir.
 - Command Line:** Saldırganın çalıştırdığı asıl Base64 kodlanmış payload buradadır. Analist olarak sonraki adımımız bu JABzAD0... dizisini CyberChef gibi bir araçla

çözmek (decode etmek) ve zararlı yazılımın hangi IP adresine bağlandığını (C2 - Command and Control sunucusu) tespit etmektir.

Bu log analizi sayesinde, sıradan bir "Alarm" sadece bir bildirim olmaktan çıkar; nereden geldiği, nereye gittiği ve nasıl durdurulacağı belli olan somut bir güvenlik vakasına (Incident) dönüşür. İşlem sonunda bu alarmin **Verdict** statüsü kesinlikle (●) **True Positive** olarak güncellenecektir.

Alarm Önceliklendirme (Alert Prioritisation)

Bir **SOC (Security Operations Center - Siber Güvenlik Operasyon Merkezi)** analistinin ekranına düşen bir alarmı okuyup anlaması, sürecin sadece ilk adımıdır. Günlük operasyonlarda yüzlerce, bazen binlerce alarmin aynı anda veya ardışık olarak fırlatıldığı bir senaryoda (bu duruma sıklıkla **Alert Fatigue - Alarm Yorgunluğu** denir), analistin hangi alarmı ilk olarak inceleyeceğine karar verme sürecine **Alert Prioritisation (Alarm Önceliklendirme)** adı verilir.



Bu süreç sıradan bir sıralama işlemi değildir; tehdidin zamanında tespiti (Time to Detect) ve sisteme verilen zararın en aza indirilmesi (Time to Respond) açısından hayati bir operasyonel karardır. Hatalı bir önceliklendirme, kritik bir **Ransomware (Fidye Yazılımı)** saldırısı ağda yayılırken, analistin zararsız bir port taraması (port scan) alarmıyla vakit kaybetmesi anlamına gelir.

Analiz İçin Doğru Alarmı Seçme Süreci (Triage Pipeline)

Her SOC ekibi kendi tehdit modellemesine ve iş kritiklik seviyelerine göre özel önceliklendirme kuralları (Playbook'lar) yazar. Bu kurallar manuel işletilmez; **SIEM (Security Information and Event Management)** veya **EDR (Endpoint Detection and Response)** çözümleri üzerinde otomatik sıralama mantıkları olarak (sorting logic) kurgulanır.

Sektörde "Altın Standart" olarak kabul edilen ve en yaygın kullanılan mantıksal ardışıklık üç temel sütuna dayanır:

1. Alarmları Filtreleme (Filtering - Efor Optimizasyonu ve Çakışmayı Önleme)

Triyaj (Triage - ilk müdahale ve sınıflandırma) sürecinin sıfırıncı adımı, incelenebilir ve aksiyona dökülebilir (actionable) olan doğru alarm havuzunu izole etmektir.

Analist, diğer takım arkadaşları tarafından halihazırda incelenen veya kapatılmış alarmları ekranından filtrelemelidir. Amacımız sadece statüsü **"New" (Yeni)** veya **"Unassigned" (Atanmamış)** olan, yani henüz insan gözü değmemiş taze vakalara odaklanmaktır.

MANTIKSAL DERİNLİK: Neden bu filtrelemeyi yapıyoruz? Eğer statü kontrolü yapmadan listeye dalarsak, operasyonel ortamda "Analyst Collision" (Analist Çakışması) yaşanır. İki farklı analistin aynı anda aynı alarmı incelemesi, sınırlı olan insan kaynağının (eforun) tamamen israf edilmesidir.

```
// Örnek bir SIEM (Splunk) Arama Mantığı (Pseudo-SPL)
index=sec_alerts (status="New" OR status="Unassigned") | dedup alert_id
```

Yukarıdaki komut, `sec_alerts` indeksindeki loglardan sadece yeni veya atanmamış olanları getirir ve `dedup` (deduplication) parametresi ile aynı `alert_id` 'ye sahip mükerrer kayıtları tekilleştirerek analistin ekranını temizler.

2. Kritiklik Derecesine Göre Sıralama (Sorting by Severity - Etki Odaklı Yaklaşım)

Doğru havuzu oluşturduktan sonraki adım, alarmları **Severity (Kritiklik Derecesi)** bazında yukarıdan aşağıya dizmektir. Sıralama her zaman şu yönde olmalıdır: **Critical (Kritik) → High (Yüksek) → Medium (Orta) → Low (Düşük)**

MANTIKSAL DERİNLİK: Neden ilk olarak "Critical" alarmlara atlıyoruz? Arka planda **Detection Engineers (Algılama Mühendisleri)**, tespit kurallarını yazarken bu derecelendirmeleri rastgele atamazlar. Bir alarm "Critical" olarak etiketlenmişse, bu iki anlama gelir:

- Yüksek İsabet Oranı (High Fidelity):** Kuralın **False Positive (Yanlış Pozitif - zararsız bir aktivitenin tehdit sanılması)** üretme ihtimali matematiksel olarak çok düşüktür. Ortada yüksek ihtimalle gerçek bir **True Positive (Gerçek Tehdit)** vardır.
- Kritik İş Etkisi (Business Impact):** Bu alarmın temsil ettiği eylem başarılı olursa, kurumun altyapısı çökecek veya verileri çalınacaktır (Örn: Domain Controller üzerinde yetkisiz bir Mimikatz kullanımı).

ÖNEMLİ: "Low" seviyesindeki bir alarm, saldırganın henüz dış kapıyı zorlaması olabilirken, "Critical" seviyesindeki bir alarm saldırganın kasanın şifresini çözdüğünün göstergesidir. Bu

yüzden her zaman kasayı korumakla işe başlanır.

3. Zamana Göre Sıralama (Sorting by Time - Dwell Time ve Kill Chain Dinamikleri)

Eğer elimizde aynı kritiklik derecesine (Örneğin 5 adet "High") sahip birden fazla alarm varsa, eşitliği bozacak olan parametre **Zaman (Time)** olmalıdır. Sıralama kuralı: **En eski alarmdan (Oldest), en yeni alarma (Newest) doğru (FIFO - First In, First Out)**.

MANTIKSAL DERİNLİK: Neden en yeni alarm varken saatler önce düşmüş eski bir alarma öncelik veriyoruz? Siber güvenlikte saldırganın ağ içinde fark edilmeden geçirdiği süreye **Dwell Time** denir.

Eğer ekranımızda biri 3 saat önce, diğeri 5 dakika önce tetiklenmiş iki farklı "High" alarm varsa:

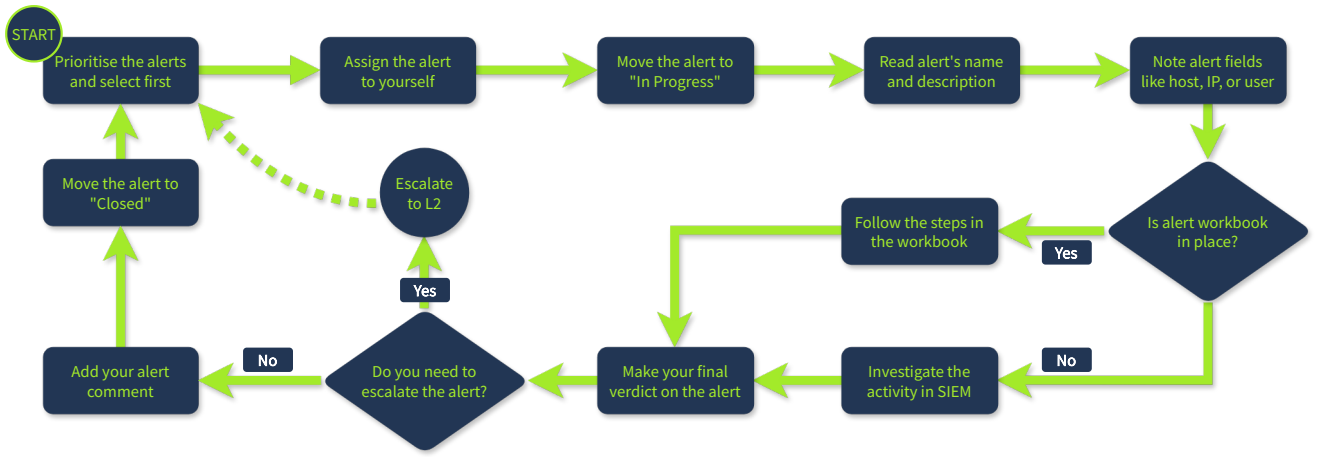
- **3 Saatlik (Eski) İhlal:** Saldırgan sistemde saatler geçirmiştir. Siber Saldırı Yaşam Döngüsünde (**Cyber Kill Chain**) son aşamalara gelmiş, hatta **Data Exfiltration (Veri Sızdırma - çalınan verilerin dışarı aktarılması)** sürecini başlatmış veya veritabanını şifreliyor olabilir. Zarar aktif olarak gerçekleşmektedir.
- **5 Dakikalık (Yeni) İhlal:** Çaylak saldırgan sisteme henüz sızmış ve sadece etrafı izlemektedir. Şu an muhtemelen ağ içinde **Discovery (Keşif - sistem yapılandırmasını ve hedefleri anlama)** aşamasındadır.

DİKKAT: "Eskiden yeniye" kuralı, aktif olarak kanayan ve ölmek üzere olan eski bir yaraya (eski ihlal) turnike uygulamak varken, henüz yeni çizilmiş bir sıyrıkla (yeni ihlal) vakit kaybetmemek için oluşturulmuş kusursuz bir mantıktır. Önce eski saldırganı sistemden atarız, sonra yeni gelenin keşif yapmasını engelleriz.

Alarm Triyajı (Alert Triage) Süreci ve Operasyonel Metodoloji

Bir Siber Güvenlik Operasyon Merkezi (**SOC**) analisti olarak, önceliklendirilmiş doğru alarmı seçtikten sonra en kritik aşamaya, yani **Alert Triage** (Alarm Triyajı) sürecine gireriz. Sektörde bu süreç; *alert handling* (alarm işleme), *alert processing* (alarm süreci yürütme) veya *alert investigation* (alarm soruşturması) gibi farklı isimlerle anılsa da, temel amaç aynıdır: Şüpheli bir aktivitenin anatomisini çıkarmak, zararlı olup olmadığına karar vermek ve sistemi güvence altına almak.

Bu süreç, yüzeysel bir onaylama işlemi değildir; ağır bir operasyonel ve analitik iş yükü gerektirir. Sürecin her bir adımı, siber saldırı yaşam döngüsünün (Cyber Kill Chain) neresinde olduğumuzu anlamak ve kalıcı bir hasar oluşmadan önce müdahale etmek için kritik bir öneme sahiptir.



İlk Aksiyonlar (Initial Actions): Sahiplik ve Çatışma Yönetimi

Triyaj sürecinin başlangıcı, teknik analizden ziyade operasyonel disiplinle ilgilidir. Ekrana düşen bir alarmı incelemeye başlamadan önce atılması gereken ilk adım, o alarmın sahipliğini (ownership) almaktır.

Siber güvenlik operasyonlarında aynı alarm üzerinde birden fazla analistin çalışması (Analyst Collision), kısıtlı zaman ve eforun israf edilmesi anlamına gelir. Bu durumu önlemek için alarm öncelikle kendi üzerinize atanmalı (Assign) ve durumu **In Progress** (Devam Ediyor) olarak güncellenmelidir. Bu statü değişikliği, ekibin geri kalanına "Bu vakayı ben devraldım ve inceliyorum" mesajını verir.

Sahiplik alındıktan sonra, alarmın teknik detaylarına aşina olma evresi başlar. Alarmın adı (örneğin; *Suspicious PowerShell Execution*), açıklaması ve alarmı tetikleyen temel belirteçler (Key Indicators - IP adresleri, dosya hash'leri, kullanıcı adları) incelenerek zihinsel bir saldırı profili oluşturulur.

Derinlemesine İnceleme (Investigation): Loglar Arasında Tehdit Avı

Bu aşama, triyaj sürecinin omurgasıdır. Teknik bilgi birikiminizin, sistem mimarisi anlayışınızın ve analitik düşünme yeteneğinizin en çok test edildiği yer burasıdır. Amacımız, **SIEM** (Security Information and Event Management) veya **EDR** (Endpoint Detection and Response) platformlarına düşen logların, meşru bir sistem davranışı mı yoksa gerçek bir saldırı mı olduğunu kanıtlamaktır.

Olgun SOC ekiplerinde, bu karmaşık analiz sürecini standartlaştırmak ve L1 (Seviye 1) analistlere rehberlik etmek için **Workbooks** (Playbooks veya Runbooks olarak da bilinir) kullanılır. Workbooks, belirli bir alarm kategorisi (örneğin Oltalama/Phishing alarmları) için adım adım hangi loglara bakılacağını, hangi IP'lerin nasıl sorgulanacağını belirten teknik operasyon yönergeleridir.

Eğer elinizin altında bir Workbook yoksa, aşağıdaki analitik mantık zincirini işletmek zorundasınız:

1. **Hedefin ve Kapsamın Tespiti:** Tehdit altında olan varlık nedir? Olayın gerçekleştiği **hostname** (makine adı), etkilenen kullanıcı (sıradan bir çalışan mı yoksa Domain Admin

mi?), bulut altyapısı veya web uygulaması tespit edilmelidir. Zararın potansiyel boyutu hedefin kritikliğine göre değişir.

2. **Aksiyonun Doğası:** Alarmin temelini oluşturan olay nedir? Şüpheli bir lokasyondan giriş (Impossible Travel), ağa sızan bir zararlı yazılım (Malware) veya gelen bir oltalama e-postası (Phishing) mı? Bu, incelemenin yönünü belirler.
3. **Zaman Bazlı Korelasyon (Surrounding Events):** Tek bir alarmı bakarak karar verilmez. Olayın hemen öncesinde ve sonrasında (genellikle +/- 15 dakika) gerçekleşen loglar taranmalıdır. **DİKKAT:** Bir "Başarısız Giriş Denemeleri (Brute Force)" alarmının hemen ardından "Başarılı Oturum Açma" logu görüyorsanız, saldırgan içeri girmiş demektir ve acil müdahale gerekir.
4. **Tehdit İstihbaratı ile Doğrulama (CTI):** Elde edilen IP adresleri, domainler veya dosya hash değerleri, dış Threat Intelligence (Siber Tehdit İstihbaratı) platformları (örn. VirusTotal, AbuseIPDB, AlienVault OTX) üzerinden sorgulanarak bulgular doğrulanmalıdır.

Nihai Aksiyonlar ve Karar Aşaması (Final Actions)

İnceleme tamamlandığında, ulaştığınız teknik kanıtlar doğrultusunda bir yargıya varmanız gerekir. Bu karar, kurumun ağında bir siber saldırıyı yakalayıp yakalamadığınızı belirler.

İlk olarak vakanın sınıflandırması yapılır:

- **True Positive (Gerçek Pozitif):** İncelenen alarmın gerçekten kötü niyetli bir aktiviteyi (malware, yetkisiz erişim) veya ciddi bir güvenlik politikası ihlalini temsil etmesidir.
- **False Positive (Yanlış Pozitif):** Sistemin, meşru ve zararsız bir kullanıcı veya sistem aktivitesini yanlışlıkla saldırı olarak algılamasıdır. (Örn: Bir sistem yöneticisinin bakım için çalıştırdığı bir Nmap taraması).

Karar verildikten sonra, analiz adımlarının ve ulaşılan kararın mantıksal dayanaklarının detaylı bir şekilde yazıya dökülmesi (Commenting) zorunludur.

ÖNEMLİ: Yetersiz veya baştan savma yazılmış bir kapanış notu, bir sonraki aşamada vakayı devralacak (Escalation) olan L2 analistlerinin veya Incident Response (Olay Müdahale) ekiplerinin kör uçuş yapmasına neden olur.

Aşağıda, endüstri standartlarında kusursuz hazırlanmış bir SOC analist kapanış notu örneği bulunmaktadır:

[Analist Kapanış Notu – Triage Tamamlandı]

Vaka Sınıflandırması: True Positive

Karar: Zararlı (Malicious)

Analiz Adımları ve Mantıksal Çerçeve:

1. "FINANCE-PC" hostname'li cihazda "powershell.exe -enc" parametresiyle Base64 şifrelenmiş bir komut çalıştırıldığı tespit edildi.
2. Olaydan 3 dakika önce "j.doe" kullanıcısının Outlook üzerinden bir e-

posta eklentisi (Invoice_2026.doc) indirdiđi EDR loglarından dođrulandı (Zaman Bazlı Korelasyon).

3. Base64 komutu decode edildiđinde, zararlı yazılımın 185.x.x.x IP adresine (C2 Sunucusu) Call-back (geri bađlantı) yapmaya çalıştıđı görüldü.

4. İlgili IP adresi VirusTotal üzerinde 45/70 oranında malicious (zararlı) olarak etiketlenmiştir.

Sonuç ve Aksiyon:

Vaka True Positive olarak deđerlendirilmiş olup, ađ izole edilmiş ve detaylı bellek analizi (Memory Forensics) için L2 Incident Response ekibine tırmandırılmıştır (Escalation).

Yukarıdaki çıktı, triyaj sürecinin sadece alarm kapatmak olmadığını, aynı zamanda dijital delillerin zincirleme bir mantıkla nasıl kayıt altına alındıđını göstermektedir. Bu detayda bir not, denetimlerde (audit) ve olay sonrası analizlerde hayat kurtarır.

Tüm bu işlemlerin ve detaylı raporlamanın ardından alarmin durumu **Closed** (Kapalı) statüsüne getirilir. Eđer vaka bir True Positive ise, analiz notuyla birlikte bir üst seviyeye **Escalation** (Tırmandırma) işlemi gerçekleştirilir.

SOC Dashboard Notları (TryHackMe Laboratuvar Dinamikleri)

TryHackMe üzerindeki SIEM/SOC simülasyonlarında öğrenme sürecini dođrulamak için bayrak (flag) mekanizması kullanılır.

- Eđer triyaj sürecini tamamlayıp alarmı kapatmanıza rağmen beklediđiniz **Flag** (Bayrak) ekrana düşmüyorsa, bu durum alarm üzerinde yaptıđınız yapılandırmalarda (True/False Positive seçimi, Alarm Statüsü ataması vb.) hatalı bir deđer girdiđinizin kesin göstergesidir. Geri dönüp logları daha dikkatli incelemeniz gerekir.
- Sistemi sıfırdan ve temiz bir şekilde tekrar ele almak isterseniz, TryHackMe SIEM arayüzünün sağ üst köşesinde bulunan **Restart** butonunu kullanarak SOC dashboard'unu (panelini) ilk haline döndürebilir ve analizinize yeniden başlayabilirsiniz.